

Accessibility Escalation — Automated Investigation & Endpoint Response

Behavior:Win32/AccessibilityEscalation.AF on dc01.corp.local — Incident 12

Incident ID	Endpoint	Primary Detection	Status
12	dc01.corp.local (Domain Controller)	Behavior:Win32/AccessibilityEscalation.AF	Resolved

Severity	Classification	Incident Tags	Analyst
Medium	Informational — Security Testing	AuthorizedSecurityTesting; AccessibilityEscalation	Edwin Dominic — SOC Analyst (L1)

1. Executive Summary

On 11 August 2026, Microsoft Defender for Endpoint detected AccessibilityEscalation behavior on dc01.corp.local, a domain controller, involving the Microsoft-signed utilman.exe accessibility binary launched with /debug under NT AUTHORITY\SYSTEM. Defender observed anomalous memory-protection activity (NtProtectVirtualMemoryApiCall) and classified the behavior as Behavior:Win32/AccessibilityEscalation.AF, terminating and remediating it automatically. The associated conhost.exe process received the same behavioral verdict.

utilman.exe and conhost.exe are both legitimate, Microsoft-signed Windows binaries with a clean VirusTotal reputation (0/70 and 0/72 respectively). This investigation evaluates file reputation and runtime behavior as independent signals rather than treating a clean hash as clearing the process (Section 3.4). The automated investigation returned "No threats found"; that result was treated as supplementary, since endpoint telemetry independently confirmed the behavioral detection and remediation (Section 7). Based on the available endpoint telemetry and completed remediation actions, no evidence currently indicated ongoing compromise or persistence requiring additional disruptive containment. Endpoint isolation was not performed, given the asset's role as a domain controller and Defender's already-successful remediation.

2. Incident Overview

Field	Value
Incident ID	12
Incident Name	'AccessibilityEscalation' detected on one endpoint
Severity	Medium
Final Status	Resolved
Classification	Informational, expected activity — Security testing
Incident Tags	AuthorizedSecurityTesting; AccessibilityEscalation
Affected Endpoint	dc01 / DC01.corp.local (Domain Controller)
Primary Detection	Behavior:Win32/AccessibilityEscalation.AF
Primary Process	utilman.exe
Associated Process	conhost.exe

Field	Value
Containment	Endpoint isolation not performed
Defender Response	Active behavior successfully terminated/remediated

3. Technical Investigation

3.1 Process Ancestry

```
smss.exe (PID 608)
  \_ winlogon.exe (PID 684)
    \_ utilman.exe (PID 6140 / 3984) /debug
      \_ conhost.exe
```

3.2 utilman.exe Evidence

Field	Value
Path	C:\Windows\System32\utilman.exe
Command Line	utilman.exe /debug
Integrity	System (NT AUTHORITY\SYSTEM)
Signer	Microsoft Windows (Microsoft Windows Production PCA 2011)
SHA1	21ae65264256fa8bbe3b69c054545781a02d82b8
SHA256	f9b78911386a6aeb3582447593a218471f40ab780cab2682f927da1ec00034e2
VirusTotal	0/70
Memory Behavior	NtProtectVirtualMemoryApiCall — anomalous memory-protection activity
Primary Verdict	Behavior:Win32/AccessibilityEscalation.AF — Remediation: remove — Result: Success

3.3 conhost.exe Evidence

Field	Value
Path	C:\Windows\System32\conhost.exe
Signer	Microsoft Windows
SHA1	4f1e9d9c9624298620312005cb218a9905c7690c
VirusTotal	0/72
Verdict	Behavior:Win32/AccessibilityEscalation.AF — same behavioral classification as utilman.exe

3.4 File Reputation vs. Runtime Behavior

Two Independent Signals

utilman.exe and conhost.exe are legitimate Microsoft-signed Windows system binaries with benign file-reputation results in the observed VirusTotal checks. The security-relevant finding is runtime behavior: execution with /debug under SYSTEM, anomalous memory-protection API activity, and a Defender behavioral verdict generated at execution time. This investigation treats file reputation and runtime behavior as two independent signals rather than assuming a clean hash clears the process.

4. MITRE ATT&CK Mapping

The incident was categorized under Defense Evasion / Suspicious Activity. Mappings reflect observed Defender telemetry and represent behavioral associations, not proof of completed compromise.

ID	Technique	Tactic	Evidence Basis
T1036.005	Match Legitimate Resource Name or Location	Defense Evasion	Incident-level AccessibilityEscalation technique context
T1036.003	Rename Legitimate Utilities	Defense Evasion	Defender telemetry associated a signed tool's internal name with utilman.exe
T1059.003	Windows Command Shell	Execution	Script-interpreter process creation observed under winlogon.exe → utilman.exe

5. Consolidated Timeline

Time	Event
15:42:17	utilman.exe and conhost.exe both detected as Behavior:Win32/AccessibilityEscalation.AF (antivirus/behavioral detection)
15:42:18 – 19	Detections reported as remediated; winlogon.exe → utilman.exe → conhost.exe process relationship recorded
15:42:25.717	Telemetry maps signed-tool renaming (T1036.003) and script-interpreter creation (T1059.003)
15:42:25.724	Anomalous memory allocation recorded in utilman.exe (NtProtectVirtualMemoryApiCall)
15:42:25.966	Suspicious AccessibilityEscalation behavior recorded as blocked
15:42:34+	Supporting network/signature telemetry follows; not used as independent proof of compromise
12 Aug	Investigation package collection and antivirus scan completed through Action Center

6. Response & Containment

Action	Target	Status
Collect Investigation Package	dc01.corp.local	Completed via Action Center on 12 August 2026
Start Antivirus Scan	dc01.corp.local	Completed via Action Center on 12 August 2026
Live Response	dc01.corp.local	Unavailable in tenant
Isolate Device	dc01.corp.local	Available — not executed (see rationale below)

Containment Rationale

Endpoint isolation was not performed. dc01.corp.local is a domain controller; disruptive isolation risks Active Directory authentication, DNS, Kerberos, and Group Policy availability. Defender had already terminated/remediated the active behavior, and no additional evidence established persistence or ongoing compromise that would outweigh that operational risk.

7. Automated Investigation Reconciliation

The automated investigation associated with Incident 12 returned "No threats found." This result is retained as supplementary evidence, not a definitive disposition: endpoint-level telemetry independently confirmed a Defender behavioral detection, anomalous memory activity, and successful remediation for both utilman.exe and conhost.exe. The automated summary was reconciled against underlying telemetry rather than treated as the sole basis for closing the incident.

8. Evidence Limitations

- Investigation package collection completed, but the package could not be downloaded from the portal; its contents were not analyzed, and no finding in this report depends on them.
- Live Response was unavailable in this tenant; no interactive endpoint commands were executed.
- VirusTotal 0/70 (utilman.exe) and 0/72 (conhost.exe) reflect file reputation only and do not negate the runtime behavioral detection.
- The exported attack-story view showed 1 impacted asset, 2 alerts, 2 evidence entities, and 2 processes. Portal and export views can represent different investigation scopes; this report does not treat that count difference as a substantive finding.

9. Final Disposition

Decision Dimension	Determination
Detection Validity	True / valid behavioral detection
Threat Context	Authorized security-testing activity
System Binaries	Legitimate, signed; maliciousness of the files themselves not established
Runtime Behavior	Security-relevant, attacker-like, successfully blocked
Containment	No isolation performed
Remediation	Successful termination/removal
Classification	Informational, expected activity — Security testing
Incident State	Resolved

10. Analyst Takeaways

- A signed Windows binary should not be labeled malware solely because Defender flags behavior involving it; correlate process ancestry, command line, integrity level, and behavioral verdicts before concluding.
- A clean VirusTotal result does not negate a runtime behavioral detection — file reputation and execution behavior are independent signals.
- A valid detection can still be operationally classified as authorized testing; that is not the same as a false positive.
- Containment decisions must weigh asset criticality — domain-controller isolation should be evidence-driven, not automatic.
- An unavailable investigation package should never be implied as analyzed; evidentiary gaps should be stated explicitly.

11. Investigation Sign-Off

Field	Value
Prepared By	Edwin Dominic — SOC Analyst (L1)

Field	Value
Investigation Type	Controlled enterprise-style SOC laboratory
Finalization Date	12 August 2026
Incident Reference	Microsoft Defender XDR — Incident 12
Disposition	Resolved — Informational, expected activity / Security testing